

7 Plan for Incident Response and Information Sharing

7.1 Cyber Incident Response Planning

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
<u>Control Definition</u> Control Objective: Ensure a consistent and effective approach for the management of cyber incidents. In-scope components: - organisational control Risk Drivers: - excess harm from deficient cyber readiness						
<u>Implementation Guidance</u> Control Statement: The user has a defined and tested cyber incident response plan. Control Context: Availability and adequate resilience are of key importance to the business. In this respect, defining and testing a cyber incident response plan is a highly effective way of reducing the impact and duration of a real cyber incident. As lessons are learnt either by testing this plan, or through real incidents, it is essential to apply these learnings and improve the plan. Planning for the sharing of threat and incident information is also critical in helping the broader financial community to implement effective protection against cyber-attacks. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). - The user has developed and annually updates a cyber incident response plan. A formal back-up and recovery plan exists for all critical business lines to support incident response activities. - The cyber incident response plan includes up-to-date contact details (internal and external when using third parties or Swift connectivity providers) and escalation timers. Such a plan is based, as a guide, on: - The Cyber Security Incident – Recovery roadmap that provides a non-exhaustive list of steps or actions that a customer must follow in case of a cyber-security breach including the need to revert to Swift Support. Details are outlined in the Swift-ISAC Bulletin #10047. - Internal security policies, laws, and regulations within a user's jurisdiction must be adhered to and considered when planning a cyber incident response. - As a minimum, the plan is reviewed on an annual basis, and tested at least every two years to make sure safe recovery of critical business operations with minimised outage time after a cyber-security incident. - The cyber incident response plan includes steps to: - Promptly notify the appropriate internal stakeholders and leadership. - Promptly notify the relevant external organisational stakeholders (typically, regulator(s), supervisor(s), law enforcement authorities).						

- Promptly notify the Swift Customer Support Centre through the default channel and to comply with other obligations applicable to users in case of a security incident including the obligation to cooperate and provide forensic support as may be required by Swift.
- Promptly contain or isolate the impacted system to limit the exposure of the attack while still being able to identify rogue activities.
- Involve skilled cyber-security professionals to identify and address the cyber incident. It is the user's responsibility to take prompt corrective action to investigate, clean the full infrastructure, and resume secure operations as soon as possible.
- Review the correctness of the user current attestation(s) and, as applicable under the Swift Security Controls Policy, invalidate such attestation(s) and submit new attestation(s).
- Conduct post-incident problem analysis to identify and remediate vulnerabilities.
- Fully document the incident.
- The user has a documented plan for the timely sharing of threat information to intelligence-sharing organisations, law enforcement, local regulators (as required in each user's jurisdiction) and to Swift. Sharing threat information may potentially support root cause analysis and sharing anonymous Indicators of Compromises (IOC) with the community.
- Information to be shared is first evaluated to make sure compliance with applicable laws and regulations (for example, privacy of personal data, confidentiality of investigations) and protects against the unintended sharing of sensitive data or data not relevant to the incident.
- The user can consume threat intelligence shared by Swift, for example in the form of IOCs.
- The user has procedures in place to:
 - Make sure the information is distributed to the correct contacts within the organisation,
 - Block traffic to/from IP-addresses/URLs mentioned in the IOCs.

Optional Enhancement:

- The user integrates the Swift ISAC automated feed solution in the environment.
- To answer extreme scenarios (such as ransomware or third-party component compromise) affecting the live, back-up, and disaster recovery environments, it might be required to set up an isolated light footprint environment. The definition, maintenance and activation, under some conditions, of such an isolated light footprint environment must be supported by a formal and up-to-date risk assessment covering the potential limited compliance due to the nature of this environment.